

STUDIO 5000 ACD- ASSOCIATED NOVEL FILE WRITES

Baseline-assisted hunt for file-write consequences compatible with project path traversal.

HUNTING / VALIDATION

CONFIDENCE: MEDIUM

STUDIO 5000 / CVE-2026-9108

Identify novel Rockwell-attributed write destinations temporally associated with ACD project activity.

ACD PROJECT

ENGINEER OPENS FILE

STUDIO PARSES PATH

NOVEL FILE WRITE

POTENTIAL IMPACT

REPORT DATE

22 July 2026

VERSION

v2.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceFileEvents

ATT&CK / SCOPE

CVE-2026-9108 ·
Consequence-oriented

Independent defensive research. Source facts, analytical assessment, assumptions and detection logic are intentionally separated. Every query requires environment-specific validation.

THREAT RESEARCH EDITORIAL STANDARD · HTML MASTER V2

01

EXECUTIVE ASSESSMENT

Decision-grade summary for threat research, detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Studio 5000 ACD-Associated Novel File Writes

CVE-2026-9108 concerns insufficient path restriction in Studio 5000 Logix Designer project handling. The hunt correlates recent ACD activity with Rockwell-attributed writes into device folders absent from a prior baseline.

WHY IT MATTERS

Operational detection value

Endpoint file events may expose the project artifact and subsequent write destinations, but cannot prove that Studio 5000 opened a crafted project or that path traversal occurred.

Medium 01

ANALYTICAL CONFIDENCE



Focused 02

TELEMETRY COVERAGE



Hunting / Validation 03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACT

Documented behavior

The vendor advisory describes ACD content capable of causing writes outside the intended directory.

ANALYTICAL ASSESSMENT

Interpretation

A novel Rockwell-attributed write near an ACD event is compatible with the consequence, but not unique to exploitation.

DETECTION ASSUMPTION

Required condition

Rockwell product metadata, relevant file writes and normal destination paths are sufficiently complete for baseline comparison.

Evidence boundary

It does not prove crafted content, project opening, path traversal, code execution or process-safety impact.

02

THREAT MECHANICS

Behavioral decomposition and observable evidence boundaries.

ATTACK FLOW



STAGE-BY-STAGE DETECTION VALUE

STAGE	BEHAVIOR	EVIDENCE EXPECTATION	USE
01	ACD project	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
02	Engineer opens file	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
03	Studio parses path	The vendor advisory describes ACD content capable of causing writes outside the intended directory.	Primary anchor
04	Novel file write	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment
05	Potential impact	Supporting process, file, identity or application context must be collected and correlated.	Context / enrichment

Observable core

A match indicates a baseline deviation compatible with the advisory's file-write consequence.

Non-observable boundary

It does not prove crafted content, project opening, path traversal, code execution or process-safety impact.

TELEMETRY & EVIDENCE MODEL

Minimum data contract required for a defensible implementation.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceFileEvents

The primary platform is selected because it observes the strongest source-supported behavior with the most direct event relationship.

EVIDENCE BOUNDARY

A match is an investigative lead.

It does not prove crafted content, project opening, path traversal, code execution or process-safety impact.

REQUIRED FIELD CONTRACT

TIER	DATA	PURPOSE	RELIABILITY
REQUIRED	Timestamp, DeviceId, FileName, FolderPath, ActionType, file origin fields, initiating-process company/product/name/command/account, SHA1, ReportId	Core filtering, grouping and investigation output.	Documented schema; population must be verified.
OPTIONAL	Signer, hash, prevalence, file origin, software inventory, device group.	Benign separation and prioritization.	Environment-dependent.
ENRICHMENT	Threat intelligence, change windows, asset criticality and identity context.	Disposition and escalation.	Integration-dependent.

Completeness

Confirm table coverage, retention, field population and event latency before measuring prevalence.

Normalization

Validate case, path, quoting, URI encoding and command-line preservation against raw events.

Visibility gap

Baseline quality and engineering change context dominate the result; active validation on production OT assets is inappropriate.

04

DETECTION LOGIC

Source-grounded implementation with explicit assumptions and outcome boundaries.

HUNTING / VALIDATION

DETECTION OBJECTIVE

Identify novel Rockwell-attributed write destinations temporally associated with ACD project activity.

IMPLEMENTATION STATUS

Hunting / Validation - Untested implementation sketch

Syntax and schema are documented; local execution, field population and false-positive performance are not established.

KQL · DEMONSTRATIVE

```
// Title: Studio 5000 ACD-Associated Novel File Writes
// Status: Hunting / validation query - not exploit proof
// Confidence: Medium
// Platform: Microsoft Defender XDR / Microsoft Sentinel with MDE tables
// Telemetry: DeviceFileEvents
// Purpose: Correlate recent .ACD project activity with Rockwell-attributed file
// writes into device folders absent from the preceding 30-day baseline.
// Vulnerability: CVE-2026-9108
// Important: A match is only compatible with a path-traversal consequence. It
// cannot prove that Studio 5000 opened a crafted project or that exploitation
// occurred.

let DetectionWindow = 1d;
let BaselineWindow = 30d;
let BaselinePaths = materialize(
    DeviceFileEvents
    | where Timestamp between (ago(BaselineWindow) .. ago(DetectionWindow))
    | where InitiatingProcessVersionInfoCompanyName has "Rockwell"
      or InitiatingProcessVersionInfoProductName has "Studio 5000"
    | extend NormalizedFolder = tolower(FolderPath)
    | summarize by DeviceId, NormalizedFolder
);

let RecentAcd = materialize(
    DeviceFileEvents
    | where Timestamp >= ago(DetectionWindow)
    | where FileName endsWith ".acd"
    | project DeviceId, DeviceName, AcdTime=Timestamp,
      AcdFileName=FileName, AcdFolderPath=FolderPath,
      FileOriginUrl, FileOriginReferrerUrl, FileOriginIP, SHA1
);

let NovelRockwellWrites =
    DeviceFileEvents
    | where Timestamp >= ago(DetectionWindow)
    | where ActionType in~ ("FileCreated", "FileModified", "FileRenamed")
    | where InitiatingProcessVersionInfoCompanyName has "Rockwell"
      or InitiatingProcessVersionInfoProductName has "Studio 5000"
    | extend NormalizedFolder = tolower(FolderPath)
    | join kind=leftanti BaselinePaths on DeviceId, NormalizedFolder
    | project DeviceId, WriteTime=Timestamp, ActionType, FileName,
      FolderPath, InitiatingProcessFileName,
      InitiatingProcessCommandLine,
      InitiatingProcessVersionInfoCompanyName,
      InitiatingProcessVersionInfoProductName,
      InitiatingProcessAccountName, ReportId;

RecentAcd
| join kind=inner NovelRockwellWrites on DeviceId
| where WriteTime between (AcdTime - 5m .. AcdTime + 30m)
| project AcdTime, WriteTime, DeviceName, AcdFileName,
  AcdFolderPath, FileOriginUrl, FileOriginReferrerUrl,
  FileOriginIP, ActionType, FileName, FolderPath,
  InitiatingProcessFileName, InitiatingProcessCommandLine,
  InitiatingProcessVersionInfoCompanyName,
  InitiatingProcessVersionInfoProductName,
  InitiatingProcessAccountName, SHA1, ReportId
```

What a match means

A match indicates a baseline deviation compatible with the advisory's file-write consequence.

What a match does not prove

It does not prove crafted content, project opening, path traversal, code execution or process-safety impact.

TRIAGE & INVESTIGATION

Evidence-led workflow for defensible disposition.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the match.
Review the raw event, timestamp, entity relationship and exact matching fields.
- 02

Establish legitimacy.
Identify the software or change owner, expected path, signer and authorized maintenance window.
- 03

Reconstruct origin.
Pivot to process, file, identity, network or application events before and after the match.
- 04

Measure prevalence.
Compare hashes, paths, commands, users and devices across the retained fleet.
- 05

Document confidence.
Separate confirmed evidence, inference, assumptions and unresolved gaps.

DECISION MODEL

Approved context → tune narrowly

Known owner, expected software path and repeatable behavior can support a documented exclusion.

Unknown context → deepen review

Rare or risky context without corroboration remains suspicious or insufficient evidence.

Corroborated activity → escalate

Malicious follow-on process, file, network, persistence or identity evidence supports incident escalation.

Host

Coverage, exposure, recent changes and neighboring alerts.

User

Session, intent, role and authorization context.

Process

Parent, child, path, command, signer and original filename.

File

Hash, signature, origin, prevalence and creation timeline.

Network

DNS, proxy, TLS and destinations following the event.

Identity

Sign-ins, token use, privilege and resource access.

OUTCOME	EVIDENCE PROFILE	ACTION
Benign	Approved and repeatable behavior with strong ownership.	Document and tune narrowly.
Suspicious	Risky context without decisive malicious corroboration.	Deepen endpoint or application review.
Likely malicious	Source-compatible match plus corroborated malicious activity.	Escalate incident response.
Insufficient evidence	Missing telemetry or unresolved ownership.	Retain evidence and validate gaps.

06

FALSE POSITIVES & VALIDATION

Operational controls required before alerting.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	LIKELIHOOD	TUNING ACTION
Engineering project updates	High	Review owner, path, signer, prevalence and change context before exclusion.
Software upgrades	High	Review owner, path, signer, prevalence and change context before exclusion.
Library imports	Med	Review owner, path, signer, prevalence and change context before exclusion.
Commissioning or maintenance	Med	Review owner, path, signer, prevalence and change context before exclusion.

Baseline plan

- Run retrospectively over a representative retention window.
- Measure volume by device, user, process, path and software owner.
- Inspect recurring legitimate patterns before adding exclusions.
- Preserve raw examples for peer review.

Validation procedure

- Confirm every required field against raw events.
- Execute only safe, authorized lab or historical validation.
- Compare query output with endpoint or application ground truth.
- Record success, rejection and sensor-failure criteria.

PROMOTION GATE

Hunting

Source-grounded hypothesis.

Candidate

Schema and baseline complete.

Production

Measured precision and runbook.

Optimized

Stable feedback loop.

Promotion criteria

Known alert volume, documented exclusions, representative validation, triage ownership, data-quality monitoring and measurable precision.

Failure condition

Baseline quality and engineering change context dominate the result; active validation on production OT assets is inappropriate.

07

ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

COVERAGE MAPPING

MAPPING	COVERAGE STATEMENT	BOUNDARY
CVE-2026-9108 · Consequence-oriented	Partial behavioral or campaign-artifact coverage of the source-supported observable.	It does not prove crafted content, project opening, path traversal, code execution or process-safety impact.

ANALYST CONCLUSION

Assessment, not certainty

The logic is assessed as a medium-confidence hunting and validation hypothesis, not exploit detection.

Residual risk

Baseline quality and engineering change context dominate the result; active validation on production OT assets is inappropriate.

REFERENCES

- 1. Security Advisories - CVE-2026-9108: <https://www.rockwellautomation.com/en-us/trust-center/security-advisories/>.html
- 2. National Vulnerability Database: <https://nvd.nist.gov/vuln/detail/CVE-2026-9108>
- 3. DeviceFileEvents table in the advanced hunting schema: <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-devicefileevents-table>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v2.0	22 July 2026	Hunting / Validation	Detection Engineering

Change summary

Migrated to the permanent Threat Research Editorial HTML master; technical query and evidence classification preserved.

Publication control

No customer data, credentials or environment-specific internal indicators are included. URLs are defanged in the publication artefact.